

FINAL TECHNICAL REPORT
Implementasi Keamanan Informasi pada Sistem Balikin



Daftar Isi

1. Pendahuluan
2. Gambaran Umum Sistem
3. Identifikasi Aset dan Ancaman
4. Implementasi Authentication
5. Implementasi Authorization
6. Implementasi Accounting (Audit)
7. Implementasi Kriptografi
8. Proteksi Tambahan
9. Pemetaan CIA Triad
10. Pengujian Keamanan
11. Screenshot Sistem
12. Panduan Instalasi & Akun Testing
13. Kesimpulan

1. Pendahuluan

1.1 Latar Belakang

Permasalahan kehilangan barang di lingkungan kampus Institut Pertanian Bogor (IPB) saat ini masih ditangani secara informal melalui grup WhatsApp, media sosial, atau papan pengumuman. Metode ini tidak terstruktur, sulit dilacak, dan tidak memiliki jaminan keamanan data bagi pelapor — seperti nomor telepon, email, dan identitas pribadi yang tersebar tanpa perlindungan.

Balikin adalah platform digital terpusat yang dirancang untuk mengatasi masalah tersebut, dengan penekanan utama pada penerapan prinsip-prinsip keamanan informasi dalam setiap aspek sistem.

1.2 Tujuan Keamanan

Laporan ini mendokumentasikan implementasi keamanan informasi pada sistem Balikin, yang berfokus pada:

1. Protokol AAA (Authentication, Authorization, Accounting) — Memastikan hanya pengguna terverifikasi yang dapat mengakses sistem sesuai perannya, dengan jejak audit yang lengkap.
2. CIA Triad (Confidentiality, Integrity, Availability) — Melindungi kerahasiaan data, menjaga keutuhan informasi, dan memastikan ketersediaan layanan.
3. Kriptografi — Menerapkan hashing, enkripsi simetris, dan token-based authentication untuk melindungi data sensitif.
4. Defense in Depth — Menerapkan beberapa lapisan keamanan (rate limiting, input validation, CORS, exception handling) sehingga jika satu lapisan gagal, lapisan lain tetap melindungi.

2. Gambaran Umum Sistem

2.1 Arsitektur Sistem

Balikin menggunakan arsitektur Client-Server berbasis REST API dengan komponen berikut:

- Frontend: React + TypeScript, Tailwind CSS, Vite (port 5173)
- Backend: FastAPI (Python), SQLAlchemy ORM, Uvicorn (port 8000)
- Database: PostgreSQL + Supabase Storage
- Komunikasi: HTTP/JWT Bearer Token

2.2 Aktor dan Role

Role	Deskripsi	Hak Akses
Pencari	Mahasiswa/civitas yang melapor kehilangan	Buat, lihat, edit, hapus laporan sendiri
Petugas	Petugas keamanan yang mengelola barang temuan	Input temuan, verifikasi, serah terima, dashboard
Admin	Administrator sistem	User management (CRUD), activity log, dashboard, toggle MFA

2.3 Tech Stack Utama

Layer	Teknologi
Frontend	React 19, TypeScript, Tailwind CSS 4, Vite 8, Axios, React Router 7
Backend	FastAPI, SQLAlchemy, Pydantic, Alembic, Uvicorn
Database	PostgreSQL
Storage	Supabase Storage (private bucket)

Layer	Teknologi
Security	python-jose (JWT), bcrypt, cryptography (Fernet), slowapi (rate limit)

3. Identifikasi Aset dan Ancaman

3.1 Aset yang Dilindungi

Aset	Tingkat Sensitivitas	Contoh Data
Kredensial Pengguna	Sangat Tinggi	Password, OTP code
Data Pribadi	Tinggi	Email, nama, nomor HP (contact_info)
Data Transaksi	Sedang	Laporan barang, status, lokasi
File Media	Sedang	Foto barang (upload)
Token Akses	Sangat Tinggi	JWT access token, refresh token
Kunci Sistem	Sangat Tinggi	SECRET_KEY, ENCRYPTION_KEY, API Keys

3.2 Ancaman dan Mitigasi

Ancaman	Vektor Serangan	Mitigasi yang Diterapkan
Brute Force Login	Percobaan password berulang	Rate limiting (5x/menit)
Password Theft	Database breach	Bcrypt hash + salt (one-way)
Session Hijacking	Token theft	Short-lived JWT (2 jam) + refresh rotation
Privilege Escalation	Akses endpoint tanpa izin	RBAC middleware + route guard
Data Exposure	Nomor HP terlihat langsung	Fernet encryption + phone masking
Credential Bypass	Login tanpa password	MFA (OTP via email)
Malicious Upload	File berbahaya diupload	Magic bytes validation + size limit
Cross-Origin Attack	Request dari domain lain	CORS whitelist
Information Disclosure	Error stack trace	Global exception handler
Unauthorized Access	Akses file storage langsung	Signed URL + proxy endpoint
Non-repudiation	Penyangkalan aksi	Activity logging + IP tracking

4. Implementasi Authentication

4.1 Password Hashing (Bcrypt + Salt)

File: backend/app/core/security.py

Tujuan: Melindungi password pengguna sehingga meskipun database dibobol, password asli tidak dapat diketahui.

Implementasi kode:

```
import bcrypt

def get_password_hash(password: str) -> str:
    salt = bcrypt.gensalt() # Generate random salt (default 12 rounds)
```

```

hashed_password = bcrypt.hashpw(password.encode('utf-8'), salt)
return hashed_password.decode('utf-8')

def verify_password(plain_password: str, hashed_password: str) -> bool:
    return bcrypt.checkpw(
        plain_password.encode('utf-8'), hashed_password.encode('utf-8')
    )

```

Analisis Keamanan

Aspek	Detail
Algoritma	Bcrypt (\$2b\$) — adaptive hash function
Salt	Random 128-bit, di-generate per password via <code>bcrypt.gensalt()</code>
Work Factor	12 rounds (default) = 2^{12} = 4096 iterasi
Penyimpanan	Format <code>\$2b\$12\$[22-char salt][31-char hash]</code> — salt embedded
Resistensi Rainbow Table	Karena salt unik per password
Resistensi Brute Force	Karena work factor tinggi
Resistensi Reverse Engineering	Karena one-way hash

Mengapa Bcrypt, bukan SHA-256?

- SHA-256 terlalu cepat, mudah di-brute-force
- Bcrypt memiliki adaptive cost — semakin kuat hardware, bisa dinaikkan
- Bcrypt otomatis mengelola salt — menghindari kesalahan developer

4.2 JWT Token Management

File: `backend/app/core/security.py`

Tujuan: Autentikasi stateless — server tidak menyimpan session, melainkan memverifikasi token yang dikirim client.

Arsitektur 3 Token

Token	Masa Berlaku	Claim type	Kegunaan
Access Token	120 menit	access	Autentikasi setiap request API
Refresh Token	7 hari	refresh	Memperbarui access token tanpa re-login
MFA Token	5 menit	mfa	Token sementara selama proses OTP

Implementasi `create_access_token`:

```

def create_access_token(subject, role=None, expires_delta=None) -> str:
    expire = datetime.utcnow() +
timedelta(minutes=settings.ACCESS_TOKEN_EXPIRE_MINUTES)
    to_encode = {'exp': expire, 'sub': str(subject), 'type': 'access'}
    if role:
        to_encode['role'] = role
    return jwt.encode(to_encode, settings.SECRET_KEY, algorithm='HS256')

```

Keamanan Token:

- HS256 (HMAC-SHA256) — Token ditandatangani dengan `SECRET_KEY`
- Token tidak menyimpan data sensitif (hanya user ID dan role)
- Access token short-lived (2 jam) untuk membatasi window of attack

- Refresh token hanya diterima di endpoint /auth/refresh
- Saat refresh gagal, user di-redirect ke login + localStorage dibersihkan

4.3 Multi-Factor Authentication (MFA/OTP)

File: backend/app/services/user_service.py & backend/app/services/email_service.py

Tujuan: Menambahkan lapisan keamanan kedua ('something you have') di atas password ('something you know'). Tersedia untuk role Petugas dan Admin.

Keamanan MFA

Aspek	Implementasi
OTP Generation	secrets.randbelow() — CSPRNG (cryptographically secure)
OTP Storage	Di-hash dengan Bcrypt sebelum disimpan (bukan plaintext)
OTP Expiry	5 menit dari generate
OTP Usage	One-time — dihapus dari DB setelah verifikasi
Transport	Email via SMTP + STARTTLS (encrypted in transit)
MFA Token	JWT terpisah bertipe mfa, berlaku 5 menit
Toggle	Hanya Petugas/Admin yang bisa mengaktifkan MFA

5. Implementasi Authorization

5.1 Role-Based Access Control (RBAC)

File: backend/app/api/deps.py

Tujuan: Memastikan setiap pengguna hanya dapat mengakses resource yang sesuai dengan perannya (Principle of Least Privilege).

Implementasi Middleware:

```
def require_role(roles: list[RoleEnum]):
    def role_checker(current_user: CurrentUser) -> User:
        user_role_str = current_user.role.value
        role_values = [r.value for r in roles]
        if user_role_str not in role_values:
            raise HTTPException(
                status_code=status.HTTP_403_FORBIDDEN,
                detail='Akses ditolak: Akun Anda tidak memiliki izin.'
            )
        return current_user
    return role_checker
```

5.2 Matriks Hak Akses (Access Control Matrix)

Endpoint	Pencari	Petugas	Admin	Public
POST /auth/login	Ya	Ya	Ya	Ya
POST /auth/register	-	-	-	Ya (Pencari only)
POST /auth/toggle-mfa	Tidak	Ya	Ya	Tidak
GET /pencari/reports	Ya	Tidak	Tidak	Tidak
POST /pencari/reports	Ya	Tidak	Tidak	Tidak

Endpoint	Pencari	Petugas	Admin	Public
PATCH /pencari/reports/{id}	Ya (own)	Tidak	Tidak	Tidak
DELETE /pencari/reports/{id}	Ya (own)	Tidak	Tidak	Tidak
GET /petugas/reports	Tidak	Ya	Tidak	Tidak
POST /petugas/reports	Tidak	Ya	Tidak	Tidak
PUT /petugas/reports/{id}	Tidak	Ya	Tidak	Tidak
GET /admin/users	Tidak	Tidak	Ya	Tidak
POST /admin/users	Tidak	Tidak	Ya	Tidak
DELETE /admin/users/{id}	Tidak	Tidak	Ya	Tidak
GET /admin/logs	Tidak	Tidak	Ya	Tidak

5.3 Frontend Route Guard

Frontend route guard bersifat UI-level protection. Keamanan sebenarnya tetap di-enforce di backend via `require_role()`. Ini adalah implementasi defense in depth — dua lapisan proteksi (frontend + backend).

5.4 Object-Level Authorization

Selain role-based, sistem juga menerapkan object-level authorization — memastikan user hanya bisa mengubah data miliknya sendiri. Pemeriksaan meliputi:

- Cek kepemilikan: `db_report.user_id != user.id` → HTTP 403
- Cek status: laporan hanya bisa diedit jika status HILANG → HTTP 400

6. Implementasi Accounting (Audit)

6.1 Activity Logging System

File: `backend/app/services/activity_log_service.py`

Tujuan: Mencatat semua aksi penting sebagai jejak audit (audit trail) untuk tujuan non-repudiation, investigasi insiden, dan compliance monitoring.

6.2 Daftar Aksi yang Dicatat

Action	Kapan Dicatat	Status	Tujuan
LOGIN	Setiap percobaan login	Berhasil / Peringatan	Deteksi brute force
LOGIN_MFA_STARTED	OTP dikirim	Berhasil	Audit MFA usage
LOGIN_MFA_FAILED	OTP salah	Peringatan	Deteksi OTP brute force
REGISTER_USER	User baru mendaftar	Berhasil	Tracking pendaftaran
CREATE_REPORT	Laporan baru dibuat	Berhasil	Audit trail laporan
UPDATE_REPORT	Status laporan diubah	Berhasil	Tracking perubahan
EDIT_REPORT	Pencari edit laporannya	Berhasil	Audit perubahan
DELETE_REPORT	Laporan dihapus	Berhasil	Audit penghapusan
CREATE_USER	Admin buat user	Berhasil	Audit admin action
UPDATE_USER	Admin ubah data user	Berhasil	Audit admin action

Action	Kapan Dicatat	Status	Tujuan
DELETE_USER	Admin hapus user	Berhasil	Audit admin action
UPDATE_PROFILE	User update profil	Berhasil	Audit perubahan
TOGGLE_MFA	MFA diaktifkan/nonaktifkan	Berhasil	Audit security setting

6.3 Data yang Disimpan per Log

Field	Contoh	Kegunaan
user_id	USR-850otdgUj4	Identifikasi pelaku
action	LOGIN	Jenis aksi
target_detail	Berhasil masuk sistem	Detail human-readable
ip_address	127.0.0.1	Lokasi jaringan pelaku
status	Berhasil / Peringatan	Hasil aksi
timestamp	2026-06-26 10:30:00	Waktu kejadian

6.4 Admin Monitoring Dashboard

Admin dapat melihat statistik audit:

- Total login berhasil vs gagal — mendeteksi anomali
- Grafik aktivitas bulanan — memantau tren penggunaan
- Filter dan pencarian log — investigasi insiden spesifik

7. Implementasi Kriptografi

7.1 Ringkasan Penggunaan Kriptografi

Data	Metode	Arah	File
Password	Bcrypt (hash + salt)	One-way (tidak bisa decrypt)	core/security.py
OTP Code	Bcrypt (hash + salt)	One-way	services/user_service.py
Contact Info (No HP)	Fernet (AES-128-CBC + HMAC)	Two-way (encrypt/decrypt)	core/encryption.py
JWT Token	HS256 (HMAC-SHA256)	Signature verification	core/security.py
Email Transport	STARTTLS	Encrypted in transit	services/email_service.py

7.2 Enkripsi Simetris (Fernet)

File: backend/app/core/encryption.py

Tujuan: Melindungi data sensitif (nomor HP pelapor) yang perlu bisa dibaca kembali oleh sistem — berbeda dengan password yang hanya perlu diverifikasi.

Implementasi:

```
from cryptography.fernet import Fernet
```



```

_cipher = Fernet(settings.ENCRIPTION_KEY.encode())

def encrypt_field(value: str) -> str:
    if not value:
        return value
    return _cipher.encrypt(value.encode()).decode()

def decrypt_field(encrypted_value: str) -> str:
    if not encrypted_value:
        return encrypted_value
    try:
        return _cipher.decrypt(encrypted_value.encode()).decode()
    except Exception:
        return encrypted_value

def mask_phone(phone: str) -> str:
    if not phone or len(phone) < 8:
        return '*****'
    return f'{phone[:4]}****{phone[-4:]}'

```

Mengapa Fernet, bukan AES manual?

- Fernet = authenticated encryption (AES + HMAC sekaligus)
- Menghindari kesalahan implementasi kriptografi manual
- IV di-generate otomatis (mencegah reuse)
- Built-in integrity check via HMAC

7.3 Manajemen Kunci

Kunci	Penyimpanan	Rotasi
SECRET_KEY (JWT signing)	Environment variable (.env)	Manual — perlu regenerate semua token
ENCRIPTION_KEY (Fernet)	Environment variable (.env)	Manual — data lama perlu re-encrypt
SUPABASE_KEY	Environment variable (.env)	Via Supabase dashboard

Best Practice yang Diterapkan:

- Kunci tidak di-hardcode dalam source code
- File .env ada di .gitignore (tidak ter-push ke Git)
- Fallback warning jika ENCRYPTION_KEY kosong (dev only)
- Setiap environment (dev/prod) menggunakan kunci berbeda

8. Proteksi Tambahan

8.1 Rate Limiting

File: backend/app/core/rate_limit.py & endpoint decorators

Tujuan: Mencegah brute force attack dan abuse dengan membatasi jumlah request per IP per waktu.

Endpoint	Limit	Ancaman yang Dimitigasi
POST /auth/login	5/minute	Brute force password
POST /auth/register	3/minute	Spam registrasi
POST /auth/refresh	10/minute	Token abuse

Endpoint	Limit	Ancaman yang Dimitigasi
POST /auth/verify-otp	10/minute	OTP brute force

8.2 Proteksi File Upload

File: backend/app/api/endpoints/upload.py

Validasi berlapis (defense in depth):

Layer	Validasi	Implementasi
1	Content-Type	file.content_type.startswith('image/')
2	File Size	Maksimal 5 MB (len(file_content) > 5 * 1024 * 1024)
3	Magic Bytes	Verifikasi header file (signature byte pertama)

Magic Bytes yang Diterima:

```
magic_bytes = {
    'jpeg': b'\xFF\xD8\xFF',      # JPEG
    'png':  b'\x89\x50\x4E\x47',  # PNG
    'gif':  b'\x47\x49\x46\x38',  # GIF
    'webp': b'\x52\x49\x46\x46',  # WebP
}
```

8.3 CORS (Cross-Origin Resource Sharing)

File: backend/app/main.py

Konfigurasi CORS membatasi origin yang diizinkan:

- Development: FRONTEND_URL=http://localhost:5173
- Production: FRONTEND_URL=https://balikin-ads2026-kelompok11.vercel.app
- Request dari domain lain akan ditolak oleh browser

8.4 Global Exception Handler

Keamanan Exception Handler:

- Error detail (stack trace, SQL query, dll.) hanya di-log di server
- Client hanya menerima pesan generic 'Internal Server Error'
- Mencegah information disclosure yang bisa dieksploitasi attacker

8.5 Private Storage dengan Signed URL

Alur Akses File:

- Client mengirim GET /api/upload/image/{filename}
- Backend (proxy) meng-generate signed URL via Supabase API (berlaku 1 jam)
- Backend mengembalikan 302 Redirect ke Supabase signed URL

File tidak bisa diakses langsung tanpa signed URL, dan signed URL expire setelah 1 jam. Backend bertindak sebagai proxy yang menyembunyikan Supabase credentials.

9. Pemetaan CIA Triad

9.1 Confidentiality (Kerahasiaan)

Implementasi	Data yang Dilindungi	Detail
Bcrypt Hash + Salt	Password, OTP	One-way, tidak bisa di-reverse
Fernet Encryption	Contact info (No HP)	AES-128-CBC + HMAC, two-way
Phone Masking	Nomor HP (tampilan)	0812****7890 — menyembunyikan digit tengah
JWT (HS256)	Session data	Signed token, bukan session ID plaintext
STARTTLS	Email OTP	Encrypted saat transit (port 587)
Private Bucket	Foto barang	Signed URL, bukan public access
Environment Variable	Kunci sistem	Tidak di-hardcode, tidak di-push ke Git
Generic Error	Internal error detail	Stack trace hanya di-log server

9.2 Integrity (Integritas)

Implementasi	Detail
Bcrypt	Password hash tidak bisa dimodifikasi tanpa diketahui
Fernet HMAC-SHA256	Mendeteksi jika ciphertext dimanipulasi
JWT Signature (HS256)	Token tidak bisa dimodifikasi tanpa SECRET_KEY
Magic Bytes Validation	Memastikan file yang diupload benar-benar gambar
Pydantic Validation	Input data divalidasi schema sebelum diproses
Object-Level Auth	User hanya bisa edit laporan milik sendiri
Status Constraint	Laporan hanya bisa diedit jika status HILANG

9.3 Availability (Ketersediaan)

Implementasi	Detail
Rate Limiting	Mencegah DoS via request berlebihan
Global Exception Handler	App tidak crash, selalu return response
Health Check Endpoint	GET /health — memantau koneksi database
Auto-Refresh Token	User tidak perlu re-login (seamless experience)
CORS Middleware	Hanya frontend terdaftar yang bisa mengakses API

10. Pengujian Keamanan

10.1 Skenario Pengujian

No	Skenario	Metode	Hasil yang Diharapkan	Status
1	Login dengan password salah	Manual	HTTP 401 + log Peringatan	Pass
2	Login melebihi rate limit (6x/menit)	Manual	HTTP 429 + pesan rate limit	Pass
3	Akses endpoint admin sebagai Pencari	Manual (Postman)	HTTP 403 Forbidden	Pass

No	Skenario	Metode	Hasil yang Diharapkan	Status
4	Akses endpoint tanpa token	Manual	HTTP 401 Unauthorized	Pass
5	Gunakan expired access token	Manual	HTTP 401 -> auto-refresh	Pass
6	Upload file non-image (.exe rename .png)	Manual	HTTP 400 Invalid image file signature	Pass
7	Upload file > 5MB	Manual	HTTP 400 File too large	Pass
8	Edit laporan user lain	Manual (Postman)	HTTP 403 Not authorized	Pass
9	Edit laporan status bukan HILANG	Manual	HTTP 400 Only reports with Hilang status	Pass
10	Input OTP setelah 5 menit	Manual	HTTP 400 OTP has expired	Pass
11	Input OTP salah	Manual	HTTP 400 + log MFA_FAILED	Pass
12	Akses Supabase file tanpa signed URL	Browser	Access Denied	Pass
13	Request dari domain berbeda (CORS)	Browser	Blocked by CORS policy	Pass

10.2 Verifikasi Hashing

Password: 'Admin123!'

Hasil hash (contoh):

\$2b\$12\$LK3qWz8mN5xZ7yJ9rC2aOeGhFdPkS6vB0mT4wX1iR3nY5qA7uVzK

Verifikasi:

- Panjang hash: 60 karakter [OK]
- Format: \$2b\$12\$ (bcrypt, 12 rounds) [OK]
- Hash berbeda tiap kali di-hash ulang (random salt) [OK]
- verify_password('Admin123!', hash) -> True [OK]
- verify_password('admin123!', hash) -> False [OK]

10.3 Verifikasi Enkripsi

Input: '081234567890'

Encrypt: 'gAAAAABnXQ...base64...=' (berubah setiap kali, karena random IV)

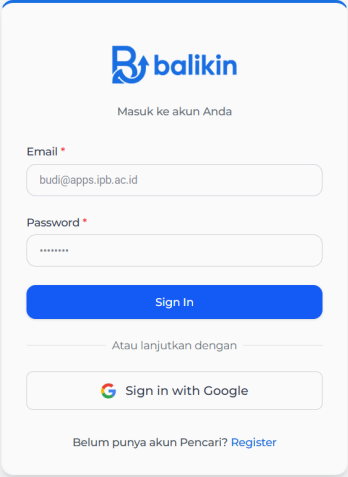
Decrypt: '081234567890' [OK]

Masked: '0812****7890' [OK]

11. Screenshot Sistem

Berikut adalah deskripsi halaman-halaman utama sistem Balikin:

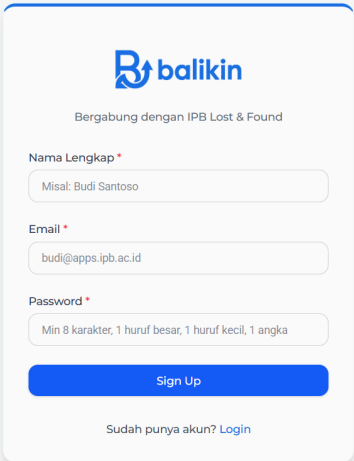
11.1 Halaman Login



The image shows a login form for 'balikin'. At the top is the 'balikin' logo. Below it is the text 'Masuk ke akun Anda'. There are two input fields: 'Email' with the value 'budi@apps.ipb.ac.id' and 'Password' with masked characters. A blue 'Sign In' button is below the password field. Below the button is the text 'Atau lanjutkan dengan' followed by a 'Sign in with Google' button. At the bottom is the text 'Belum punya akun Pencari? [Register](#)'.

Form autentikasi dengan input Email dan Password, branding Balikin.

11.2 Halaman Registrasi



The image shows a registration form for 'balikin'. At the top is the 'balikin' logo. Below it is the text 'Bergabung dengan IPB Lost & Found'. There are three input fields: 'Nama Lengkap' with the value 'Misal: Budi Santoso', 'Email' with the value 'budi@apps.ipb.ac.id', and 'Password' with the value 'Min 8 karakter, 1 huruf besar, 1 huruf kecil, 1 angka'. A blue 'Sign Up' button is below the password field. At the bottom is the text 'Sudah punya akun? [Login](#)'.

Form pendaftaran akun Pencari baru dengan validasi password (min 8 karakter, 1 huruf besar, 1 kecil, 1 angka).

11.3 Pencari — Beranda

Platform Bantuan Kehilangan & Penemuan Barang IPB

Platform terintegrasi untuk melaporkan barang hilang dan menemukan pemiliknya dengan lebih mudah, aman, dan transparan.



Landing page menampilkan hero section dan daftar barang hilang/ditemukan.

11.4 Pencari — Buat Laporan Kehilangan

Buat Laporan Kehilangan

Nama Barang *

Misal: Dompet Hitam

Kategori *

Pilih Kategori

Lokasi Terakhir Terlihat *

Misal: Gedung Kuliah Umum (SKU)

Kontak (No HP / WA) *

Misal: 08123456789

Deskripsi Detail *

Deskripsikan barang secara detail (warna, isi, ciri khusus)...

Foto Barang (Opsional)

Klik untuk upload foto

PNG, JPG maksimal 10MB

Penduan Foto

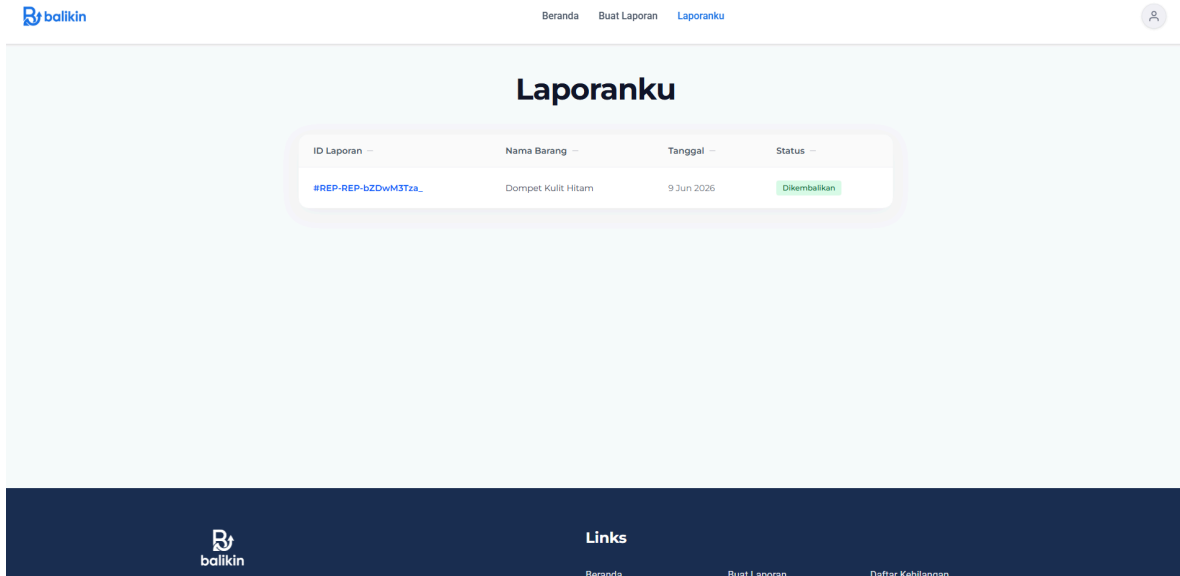
"Opsional: Tambahkan foto barang (jika ada foto lama) untuk memudahkan pencari mencocokkan barang temuan dengan laporan Anda."

Batal

Kirim Laporan

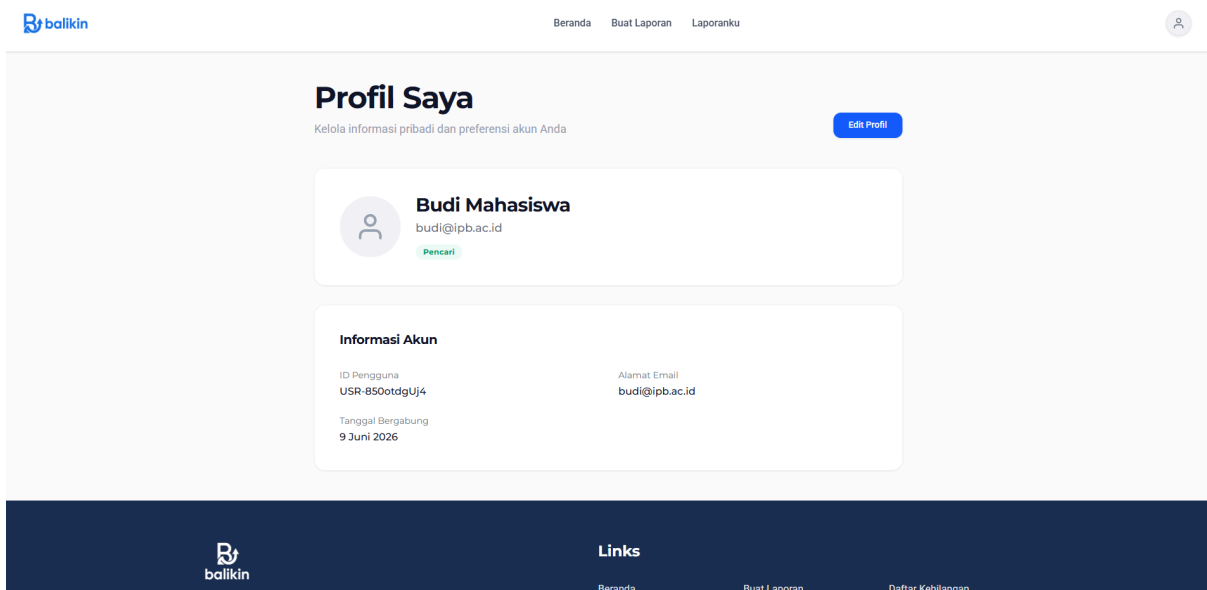
Form pelaporan dengan field: Nama Barang, Kategori, Lokasi, Kontak (dienkripsi), Deskripsi, Foto (opsional).

11.5 Pencari — Laporkan



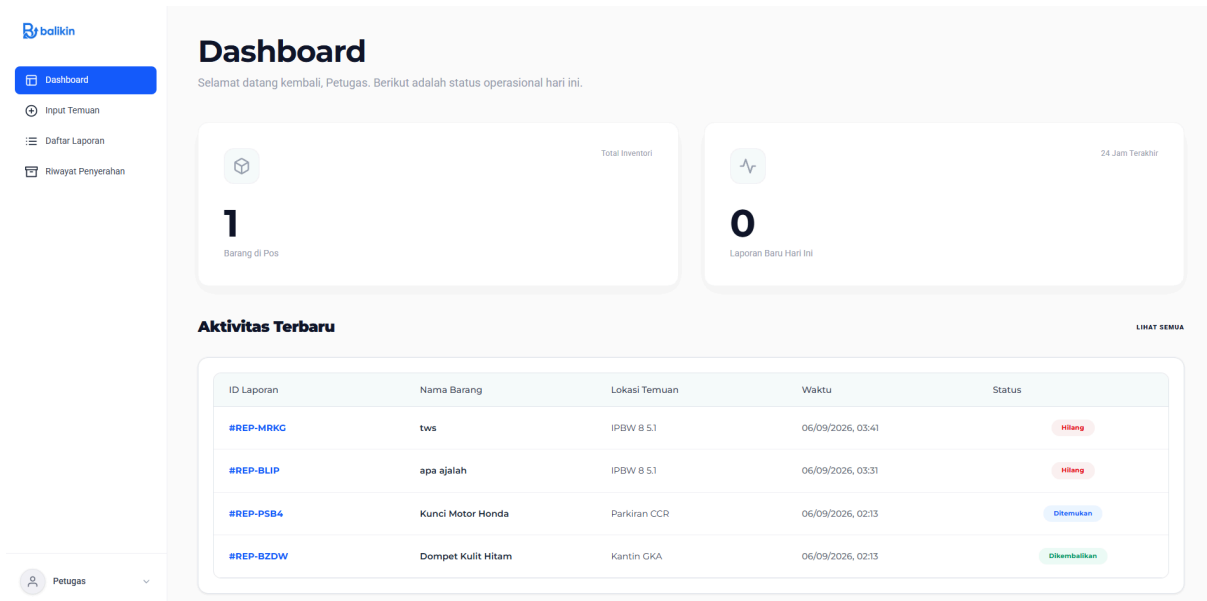
Daftar laporan user dengan status tracking (Hilang -> Ditemukan -> Diproses -> Dikembalikan).

11.6 Pencari — Profil Saya



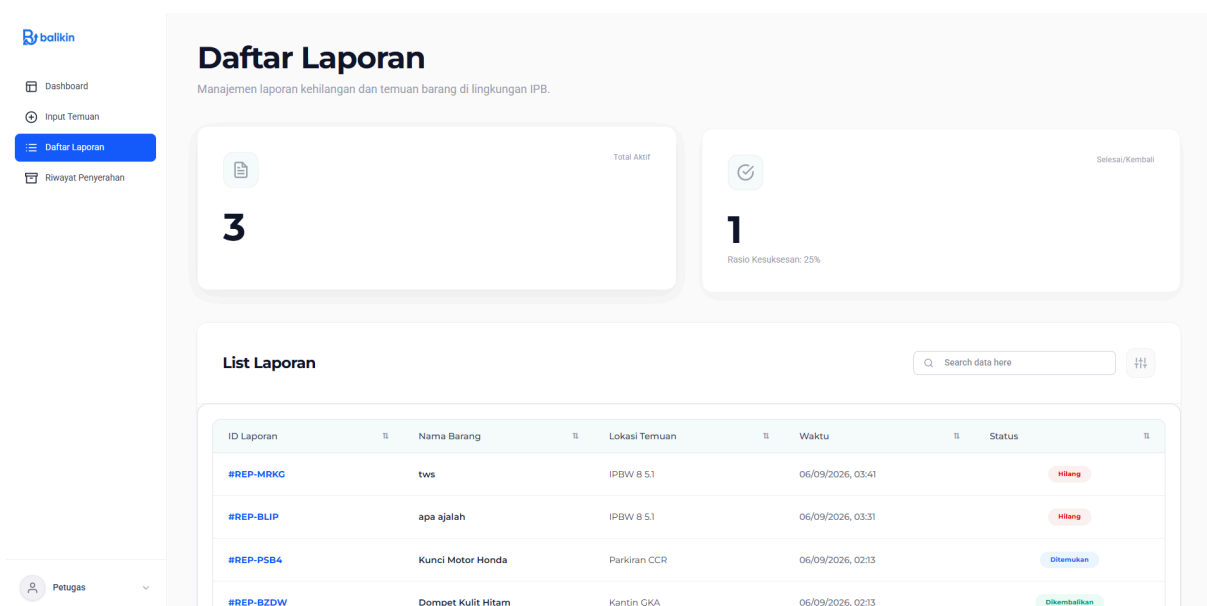
Informasi akun: nama, email, role, ID pengguna, tanggal bergabung. Tombol Edit Profil.

11.7 Petugas — Dashboard



Dashboard operasional: Total Inventori, Laporan Baru Hari Ini, Aktivitas Terbaru.

11.8 Petugas — Daftar Laporan



Manajemen laporan: Total Aktif, Selesai/Kembali, Rasio Kesuksesan, List Laporan dengan search & filter.

11.9 Petugas — Input Temuan Baru

balikin

Dashboard
Input Temuan
Daftar Laporan
Riwayat Penyerahan

Petugas

Input Temuan Baru

Dokumentasikan barang temuan dengan detail untuk proses verifikasi.

Detail Laporan

Nama Penemu *

Pilih nama penemu...

Nama Barang *

Contoh: Tumbler Hydroflask Biru 32oz

Kategori *

Pilih Kategori

Waktu Kejadian *

26 Juni 2026 05:50

Lokasi Kejadian *

Misal: Perpustakaan LSI, Meja Belajar Utara

Kontak (No HP / WA) *

Misal: 08123456789

Deskripsi Detail *

Deskripsikan barang temuan (warna, merk, ciri khusus, isi di dalamnya)...

Foto Barang (Opsional)

Panduan Foto

*Pastikan pencahayaan cukup dan foto memuat informasi yang benar-benar

Form input barang temuan: Nama Penemu, Nama Barang, Kategori, Waktu, Lokasi, Kontak, Deskripsi, Foto.

11.10 Petugas — Riwayat Penyerahan

balikin

Dashboard
Input Temuan
Daftar Laporan
Riwayat Penyerahan

Petugas

Riwayat Penyerahan

Manajemen laporan kehilangan dan temuan barang di lingkungan IPB.

Total Penyerahan

1

Kumulatif Semester Ini

Penyelesaian Hari Ini

0

+0 dari Kemarin

Riwayat Penyerahan

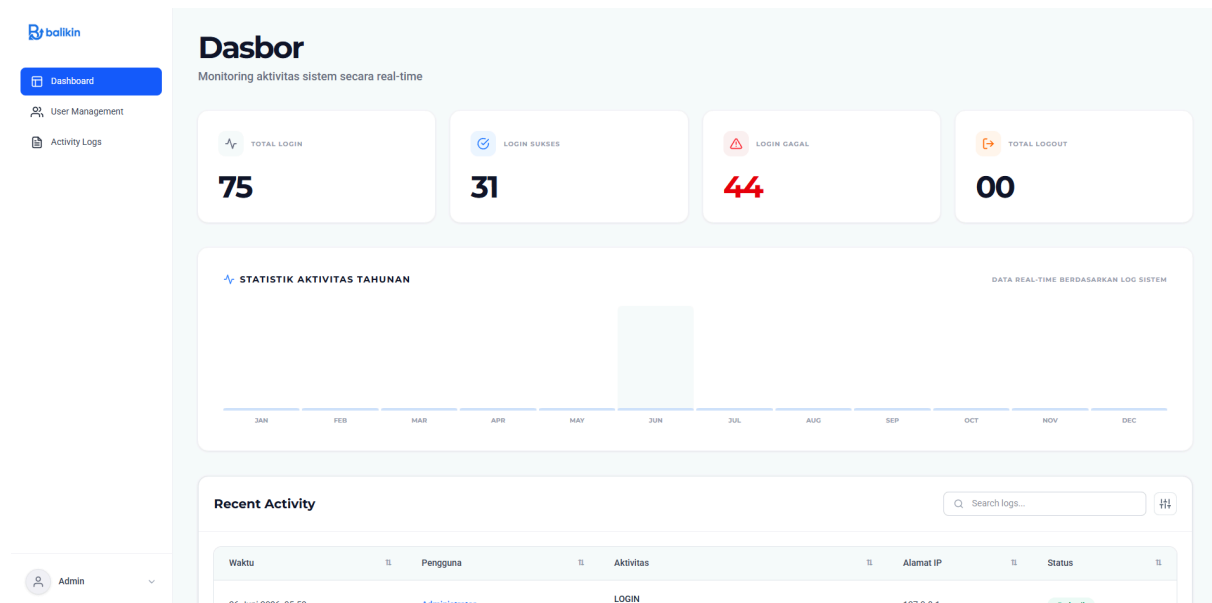
Search data here

ID Laporan	Nama Barang	Tanggal Selesai	Penerima	Petugas
#REP-BZDW	Dompot Kulit Hitam	06/09/2026, 02:13	Budi Mahasiwa	Budi Mahasiwa

Menampilkan 1 dari 1 entri

Rekap serah terima: Total Penyerahan, Penyelesaian Hari Ini, tabel detail.

11.11 Admin — Dashboard, User Management & Activity Log



Fitur Admin meliputi: Dashboard (statistik total user, total petugas, total log, login berhasil/gagal, grafik aktivitas bulanan), User Management (CRUD user untuk semua role), Activity Log (monitoring seluruh aktivitas sistem / audit trail viewer).

12. Panduan Instalasi & Akun Testing

12.1 Prasyarat

Node.js v16+, Python v3.10+, PostgreSQL v13+

12.2 Setup Cepat

```
# 1. Clone repository
git clone https://github.com/<username>/IPB-Lost-Found.git && cd
IPB-Lost-Found

# 2. Setup backend
cd backend
python -m venv venv && .\venv\Scripts\Activate
pip install -r requirements.txt

# 3. Konfigurasi .env (lihat .env.example)
# 4. Seed database
python seed.py

# 5. Jalankan backend
uvicorn app.main:app --reload      # -> http://localhost:8000

# 6. Setup frontend (terminal baru)
cd frontend && npm install && npm run dev  # -> http://localhost:5173
```

12.3 Akun Testing

Role	Email	Password	MFA
Admin	bripankom0@gmail.com	Admin123!	Aktif (OTP Email) (Tersedia)
Petugas	petugas@ipb.ac.id	Petugas123!	Nonaktif (Tersedia)
Pencari	budi@ipb.ac.id	Pencari123!	Nonaktif

13. Kesimpulan

Sistem Balikin telah berhasil mengimplementasikan keamanan informasi secara komprehensif sesuai framework AAA dan prinsip CIA Triad.

Ringkasan Implementasi Keamanan

Framework	Komponen	Implementasi	Status
AAA	Authentication	JWT (Access + Refresh + MFA), Bcrypt, OTP Email	Selesai
	Authorization	RBAC (3 roles), Object-level auth, Route guard	Selesai
	Accounting	Activity logging, IP tracking, audit trail	Selesai
CIA	Confidentiality	Fernet encryption, bcrypt hash, masking, signed URL	Selesai
	Integrity	HMAC, JWT signature, magic bytes, Pydantic validation	Selesai
	Availability	Rate limiting, exception handler, health check	Selesai
Tambahan	Defense in Depth	Multi-layer validation (frontend + backend + DB)	Selesai
	Least Privilege	Setiap role hanya memiliki hak akses minimum	Selesai
	Secure by Default	Error tidak expose detail, MFA default aktif untuk admin	Selesai

Total Mekanisme Keamanan yang Diterapkan

5. Password Hashing (Bcrypt + Salt, 12 rounds)
6. JWT Authentication (Access + Refresh + MFA token)
7. Multi-Factor Authentication (OTP 6-digit via email)
8. Fernet Symmetric Encryption (AES-128-CBC + HMAC)
9. Role-Based Access Control (RBAC, 3 roles)
10. Object-Level Authorization
11. Activity Logging + IP Tracking
12. Rate Limiting (per-endpoint)
13. File Upload Validation (content-type, size, magic bytes)
14. Private Storage + Signed URL
15. CORS Whitelist
16. Global Exception Handler
17. Phone Number Masking
18. SMTP + STARTTLS (encrypted email transport)
19. Environment Variable untuk secrets (tidak hardcoded)